

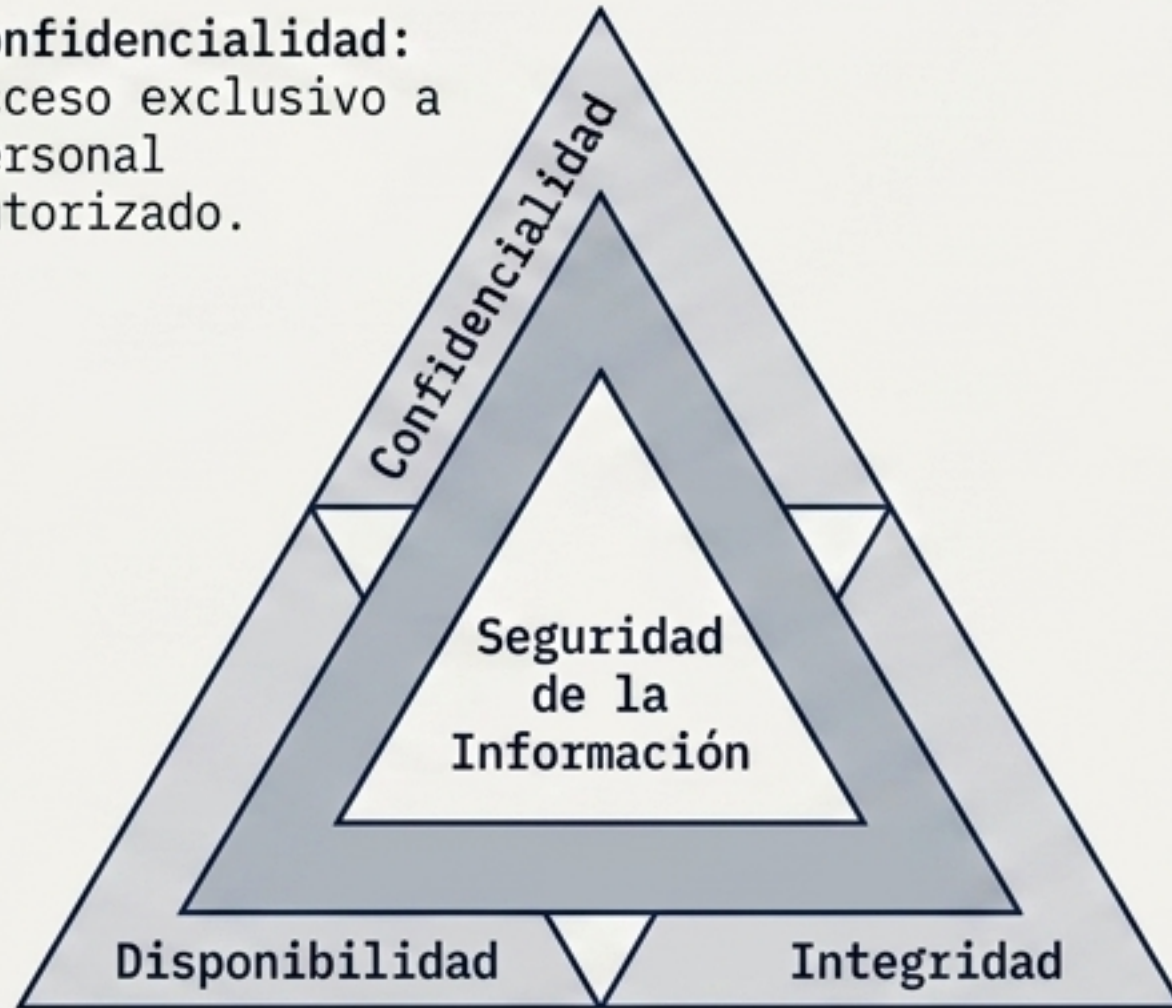
Arquitectura de Defensa Digital

Estrategias, herramientas y mitigación de amenazas en sistemas informáticos.

Fuente: Tema 13 - Sistemas Informáticos

EL NÚCLEO DE SEGURIDAD

Confidencialidad:
Acceso exclusivo a personal autorizado.



Disponibilidad:
Información accesible siempre que se necesite.

Integridad:
Datos intactos, sin modificaciones no autorizadas.

MATRIZ DE CLASIFICACIÓN

Física vs. Lógica

Hardware (cerraduras, control de acceso) vs. Software (antivirus, cortafuegos).

Activa vs. Pasiva

Activa (Prevenir el fuego): Contraseñas, cifrado.

Pasiva (Sobrevivir al fuego): Sistemas SAI, copias de seguridad.

Protocolos Base de Seguridad Corporativa

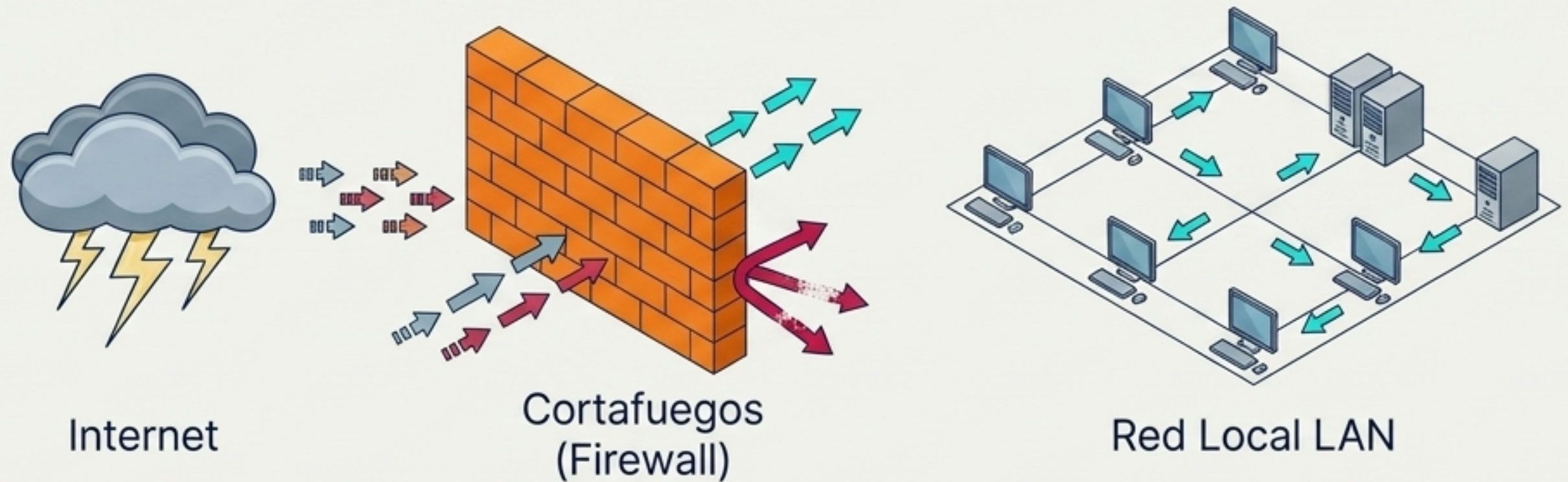
[✓]		[✓]		[✓]		[✓]	
Políticas de Backup: Copias de seguridad periódicas y redundantes.		Control de Acceso: Contraseñas seguras y restricción física al CPD.		Cifrado: Protección criptográfica para datos confidenciales.		Auditoría y Mantenimiento: Auditorías periódicas e inventario de activos.	

[!] El Eslabón Crítico: El Factor Humano

Por mucha inversión tecnológica, sin concienciación y formación del empleado (según directrices del CCN), el sistema sigue siendo frágil.

CONCEPTO DE CORTAFUEGOS

Cortafuegos (Firewall):
Dispositivo físico o lógico
que controla el tráfico
entrante y saliente para
evitar accesos no
autorizados.



EJECUCIÓN PRÁCTICA (UFW)

```
enrique@enrique-Virtual-Machine:~$ sudo ufw enable // Habilita el cortafuegos
[sudo] contraseña para enrique:
El cortafuegos está activo y habilitado en el arranque del sistema
enrique@enrique-Virtual-Machine:~$ sudo ufw status // Verifica el estado activo
Estado: activo
enrique@enrique-Virtual-Machine:~$ sudo ufw allow 56/tcp // Abre el puerto 56 TCP
Regla añadida
Regla añadida (v6)
enrique@enrique-Virtual-Machine:~$ sudo ufw deny from 192.168.1.114 // Bloquea IP específica
Regla añadida
enrique@enrique-Virtual-Machine:~$ _
```


Threat Radar

Vectores de Intrusión



HACKERS:

Buscan datos o beneficios, sin dañar el sistema per se.



CRACKERS:

Su objetivo principal es la destrucción o daño del sistema.



SNIFFERS:

Rastrean la red pasivamente para interceptar credenciales.



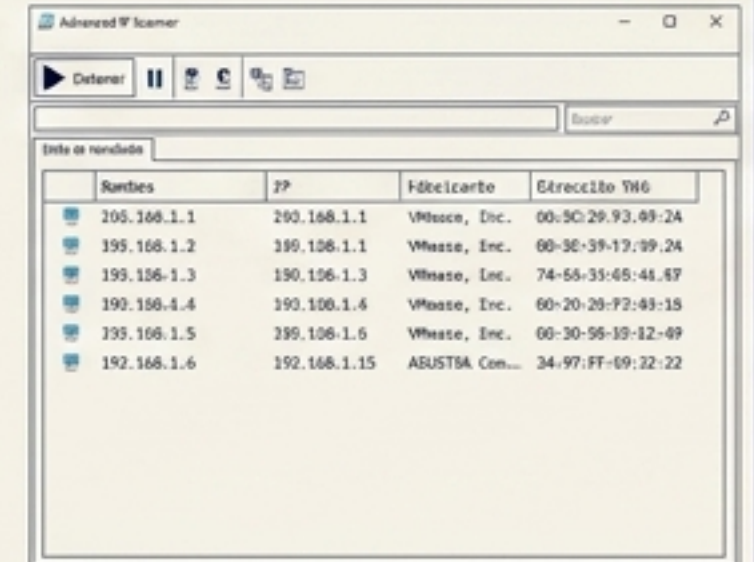
PHREAMMERS:

Saturan servidores enviando mensajes masivos.

Vigilancia de Red

Advanced IP Scanner:

Mapeo de red.
Muestra nombres, IP,
y direcciones MAC.



Hostes	IP	Nombre	Dirección MAC
205.168.1.1	205.168.1.1	VHase, Inc.	00:50:29:93:09:24
199.168.1.2	199.168.1.1	VHase, Inc.	00:30:39:17:09:24
199.168.1.3	199.168.1.3	VHase, Inc.	74-65-35-65-41-87
199.168.1.4	199.168.1.4	VHase, Inc.	00:20:29:F2:43:18
199.168.1.5	199.168.1.6	VHase, Inc.	00:30:39:17:09:24
192.168.1.6	192.168.1.15	ABUSTSA Com...	24:97:FF:09:32:22

Snort (IDS):

Sistema de Detección de Intrusión (1998).
Analiza protocolos y registra actividad sospechosa.

Instalación: `sudo apt-get install snort`

Defensa Interna: Antivirus y Herramientas

Mecanismos de Detección



Reactiva (Basada en Firmas):

Compara archivos contra una base de datos conocida.

Pro: Muy precisa.

Con: Inútil contra amenazas nuevas.

||



Proactiva (Heurística):

Analiza el comportamiento anómalo.

Pro: Detecta amenazas desconocidas.

Con: Riesgo de falsos positivos.

Arsenal Complementario



Getsusp (McAfee):

Búsqueda puntual de malware no residente.



Antimalwarebytes:

Especialista en programas no deseados.



Adwcleaner:

Limpieza específica de publicidad invasiva.



TDSSKiller (Kaspersky):

Detección y eliminación de rootkits.



MSRT (Windows):

Ejecución mensual vía Windows Update.

Protección de Datos en Reposo: Cifrado



1

El Concepto

Transforma la información en código ilegible sin la clave criptográfica.

2

El Escenario

Si se roba el dispositivo, el cifrado actúa como barrera final. Límite de intentos provoca el formateo.

3

La Herramienta

BitLocker (Windows).
Permite bloquear discos duros mediante contraseña o PIN.

BitLocker (H:)

Escriba la contraseña para desbloquear esta unidad.

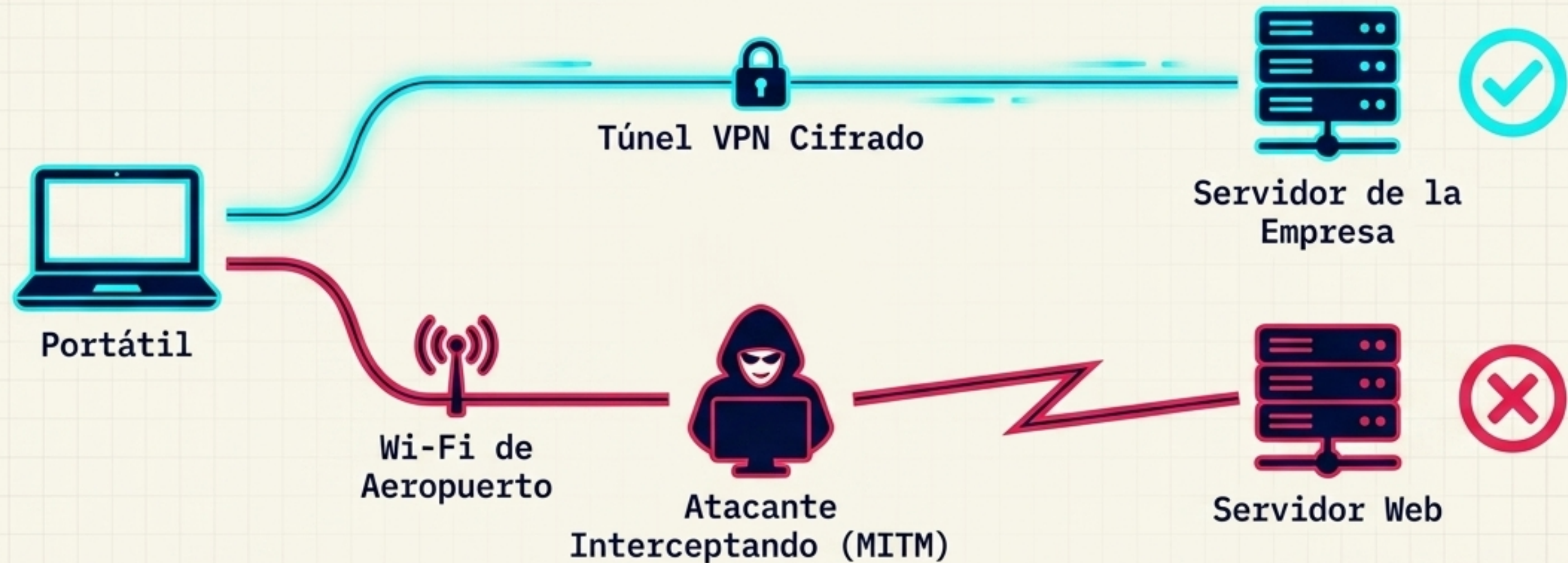
••••••••|

Desbloquear

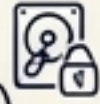
Más opciones

Caso Práctico 1: El Trabajador en Remoto

Contexto: Conexión mediante redes Wi-Fi públicas en aeropuertos con datos corporativos.



Soluciones Tácticas

1. Cifrar discos con BitLocker (protección física). 

2. Usar red VPN corporativa (túnel seguro). 

3. Evitar Wi-Fi pública; usar hotspot móvil. 

Taxonomía de Amenazas Lógicas

Infección y Propagación	Ocultación y Control	Vulnerabilidades	Robo y Engaño
Virus: Archivo ejecutable que infecta otros programas.	Caballos de Troya: Simulan ser software legítimo.	Bugs: Errores de programación.	Spyware: Robo sigiloso de datos.
Gusanos (Worms): Se propagan automáticamente por la red.	Backdoors: Atajos no cerrados que permiten acceso furtivo.	Exploits: Programas que aprovechan bugs.	Adware: Invasión publicitaria.
		Bombas Lógicas: Malware que detona bajo una condición.	Spoofing: Suplantación técnica.
			Phishing: Fraude psicológico.

Vector de Ataque Crítico: Ransomware

El Ataque



El Ataque: Infección que toma el control del equipo, cifra los archivos y exige un rescate económico (Ej. WannaCry 2017).

Directrices de Mitigación CCN-CERT



Bloquear puertos vulnerables:
137, 138 UDP y 139, 445 TCP.



Sistema Backup 3-2-1: Al menos 2 copias recientes almacenadas fuera del servidor principal.



Actualización rigurosa de sistemas operativos y navegadores.

Ataques de Fuerza Bruta

Objetivo: Credenciales

Mecanismo

Software que prueba millones de secuencias de caracteres por segundo para adivinar una contraseña.

Defensas

Limitar intentos de acceso, exigir contraseñas complejas, implementar Autenticación de Doble Factor (2FA).



Denegación de Servicios (DoS)

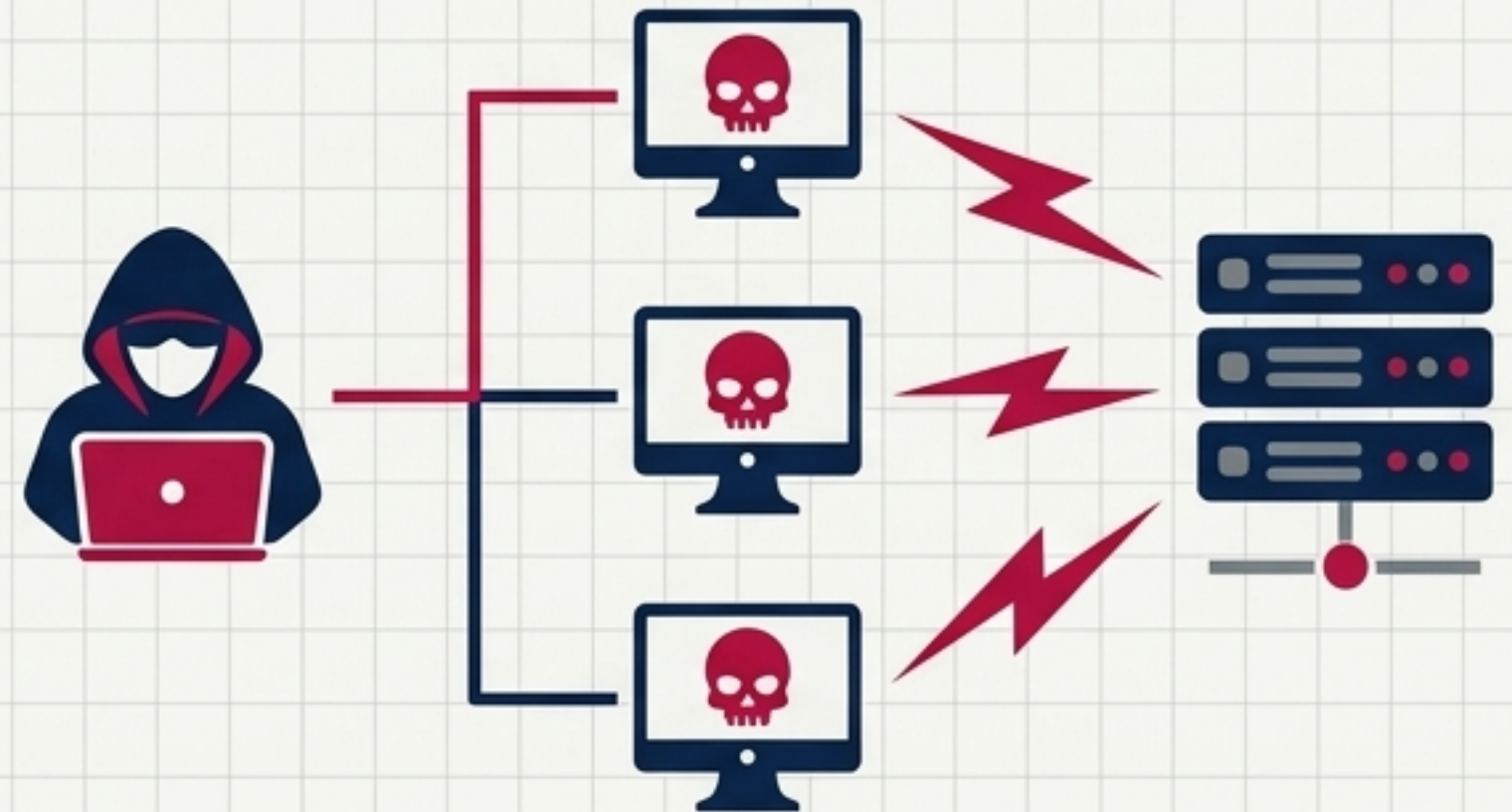
Objetivo: Recursos del Servidor

Mecanismo

Una red de bots satura un servidor con miles de peticiones simultáneas hasta colapsarlo.

Defensas

Cortafuegos perimetrales, Sistemas IDS para detectar patrones, mantener servidores actualizados.



La Última Vulnerabilidad: Ingeniería Social

El Concepto



El hackeo de la psicología humana. Atacantes simulan ser entidades de confianza para obtener credenciales.

Decálogo de Defensa (Protocolo INCIBE)

1. Verificar minuciosamente el remitente y la URL antes de hacer clic.
2. Jamás abrir ficheros adjuntos inesperados.
3. Nunca facilitar contraseñas por teléfono o correo.
4. Ante la menor duda, eliminar el mensaje y contactar por la vía oficial.

Caso Práctico 2: Autopsia de un Phishing

Banco Santander

 santander@sac.info

1 Alerta: El dominio no pertenece a la entidad financiera oficial.

→ Reenviar ...

ma. 07/08/ 17:19

Estimado Cliente:

Durante nuestro mantenimiento regular y procesos de verificación, hemos detectado una serie de errores en la información registrada de su cuenta.

Por este motivo, Banco Santander cuenta con las máximas medidas de seguridad para garantizar la confidencialidad de las comunicaciones entre el Banco y el cliente. No obstante, estas medidas pueden cambiar sin notificación, con el fin de proteger sus datos personales.

Este correo le ha sido enviado automáticamente por nuestro sistema, como notificación de los cambios efectuados en el sistema. Para verificar la actividad de la misma y omitir el proceso de baja, debe entrar en su cuenta haciendo click en el siguiente enlace:

[Activación](#)

2 Alerta: Enlace ofuscado. La URL de destino es una trampa para instalar malware.

NOTA:

Si la información en su cuenta no se actualiza, el acceso a su cuenta será restringido hasta que podamos verificar que Ud. es el titular de la cuenta.

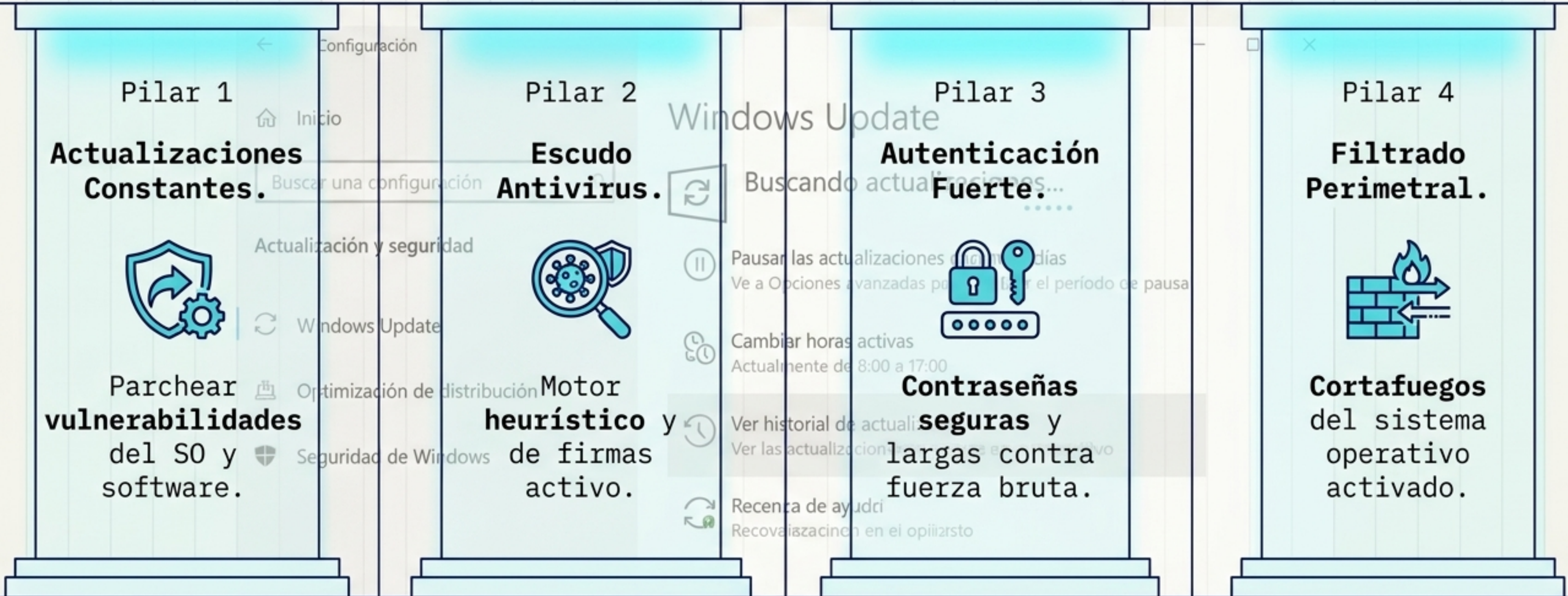
Todos los Derechos Reservados 2018© BancoSantander

Protocolo de Reacción

1. NO hacer clic.
2. Acceder al banco tecleando la URL habitual en el navegador.
3. El administrador debe bloquear el dominio remitente en el servidor de correo.

Postura de Seguridad Óptima (Resolución)

El resumen de medidas vitales que todo puesto de trabajo debe tener habilitado:



La seguridad informática no es un producto que se compra, es un proceso continuo que se practica.